NGHIÊN CỨU KỸ THUẬT KHAI THÁC VÀ PHÒNG CHỐNG TẤN CÔNG MAN-IN-THE-MIDDLE

Sinh viên thực hiện: **Nguyễn Thị Kỳ Duyên**
MSSV: 0023410647 – Lớp: ĐHCNTT23B-CS

Khoa Công nghệ và Kỹ thuật, Trường Đại học Đồng Tháp
Ngành: Khoa học máy tính – Chuyên ngành: Mạng Máy Tính và An Ninh
Giảng viên hướng dẫn: TS. Lương Thái Ngọc

Năm học 2026 – 2027

Nội dung trình bày

1. Đặt vấn đề & Mục tiêu nghiên cứu
2. Các kỹ thuật khai thác & dẫn đường MitM
3. Mô hình phòng thử nghiệm (Testbed Lab)
4. Giải pháp phòng chống & Kiểm chứng thực nghiệm
5. Đánh giá kết quả & Kết luận

Nội dung

1. Đặt vấn đề & Mục tiêu nghiên cứu
2. Các kỹ thuật khai thác & dẫn đường MitM
3. Mô hình phòng thử nghiệm (Testbed Lab)
4. Giải pháp phòng chống & Kiểm chứng thực nghiệm
5. Đánh giá kết quả & Kết luận

Tính cấp thiết của đề tài

- **Bối cảnh an toàn mạng hiện đại:**
  - Mọi giao dịch ngân hàng, định danh cá nhân và dữ liệu doanh nghiệp đều luân chuyển qua hạ tầng mạng máy tính.
  - Môi trường mạng LAN truyền thống thường bị ngộ nhận là "an toàn nội bộ".
- **Điểm yếu cố hữu của các giao thức TCP/IP sơ khai:**
  - Giao thức ARP (RFC 826), DNS (RFC 1035), DHCP (RFC 2131) **thiếu hoàn toàn cơ chế xác thực nguồn gốc**.
  - Các thiết bị mù quáng tiếp nhận thông tin phản hồi mà không kiểm tra tính xác thực.
- **Nguy cơ từ tấn công Man-in-the-Middle (MitM):**
  - Kẻ tấn công bí mật chèn vào giữa kênh truyền, nghe lén mật khẩu, trích xuất Cookie, chiếm đoạt phiên và giả mạo nội dung.

Mục tiêu và phạm vi đề tài

Mục tiêu nghiên cứu

- Hệ thống hóa các kỹ thuật dẫn đường: ARP, DNS, DHCP Spoofing, SSL Stripping.
- Phân tích các kỹ thuật tấn công phiên: Session Hijacking, Cookie Theft, Tampering.
- Dựng Lab thực nghiệm 5 node và triển khai tấn công kiểm chứng.
- Cấu hình giải pháp phòng thủ: HTTPS/HSTS, DAI, DHCP Snooping, VPN, Arpwatch.

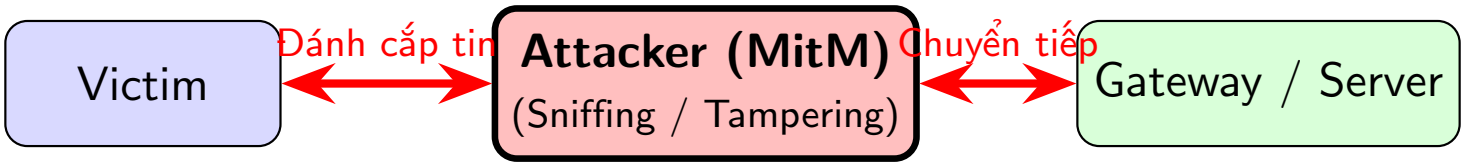
Phạm vi đề tài

- Môi trường thử nghiệm an toàn độc lập (Isolated Testbed Lab).
- Thiết bị: Kali Linux, 02 máy nạn nhân (Win/Linux), Gateway, Web Server và Switch quản lý.
- Đo kiểm định lượng trước và sau khi kích hoạt các giải pháp an ninh.

Nội dung

1. Đặt vấn đề & Mục tiêu nghiên cứu
2. Các kỹ thuật khai thác & dẫn đường MitM
3. Mô hình phòng thử nghiệm (Testbed Lab)
4. Giải pháp phòng chống & Kiểm chứng thực nghiệm
5. Đánh giá kết quả & Kết luận

Khái niệm tấn công Man-in-the-Middle



- **Bản chất:** Kẻ tấn công đứng giữa luồng truyền thông, giả mạo Gateway đối với Victim và giả mạo Victim đối với Gateway.
- **Mục tiêu:** Nghe lén (Eavesdropping), đánh cắp định danh (Credentials), chiếm quyền phiên (Session Hijacking), giả mạo nội dung (Tampering).

Kỹ thuật ARP Spoofing / Poisoning

- **Nguyên lý:** Gửi liên tục các gói tin **ARP Reply giả mạo hai chiều**:
  - Nói với Victim: *"IP Gateway hiện đang mang địa chỉ MAC của Attacker"*.
  - Nói với Gateway: *"IP Victim hiện đang mang địa chỉ MAC của Attacker"*.
- **Kết quả:** Bảng ARP Cache của cả hai bên bị nhiễm độc.
- **Bật chuyển tiếp gói tin (IP Forwarding):** `sysctl -w net.ipv4.ip_forward=1` $\rightarrow$ Lưu lượng đi qua máy Attacker một cách trong suốt, không làm rớt mạng nạn nhân.

Kỹ thuật DNS Spoofing, DHCP Spoofing & SSL Stripping

- **DNS Spoofing:** Đón đầu truy vấn UDP cổng 53, trả lời bản ghi A Record giả mạo trỏ về Web Server lừa đảo của Attacker.
- **DHCP Spoofing (Rogue DHCP):** Dựng máy chủ DHCP lậu, phản hồi nhanh hơn máy chủ thật để cấp phát Default Gateway và DNS Server trỏ thẳng về Attacker.
- **SSL Stripping (Moxie Marlinspike):**
  - Đón đầu gói tin chuyển hướng HTTP 301/302.
  - Duy trì kết nối HTTPS với Server thật nhưng hạ cấp xuống **HTTP bản rõ** khi phản hồi cho Victim.
  - Nạn nhân không thấy ổ khóa HTTPS nhưng trang web vẫn hiển thị, mọi mật khẩu nhập vào đều bị lộ.

Các kiểu tấn công vào phiên và dữ liệu

Session Hijacking & Cookie Theft

- Bắt gói tin HTTP chứa Cookie phiên (`PHPSESSID`, Token).
- Tiêm Cookie vào trình duyệt máy Attacker để truy cập thẳng hệ thống không cần mật khẩu.
- Khai thác Cookie thiếu cờ `Secure` và `HttpOnly`.

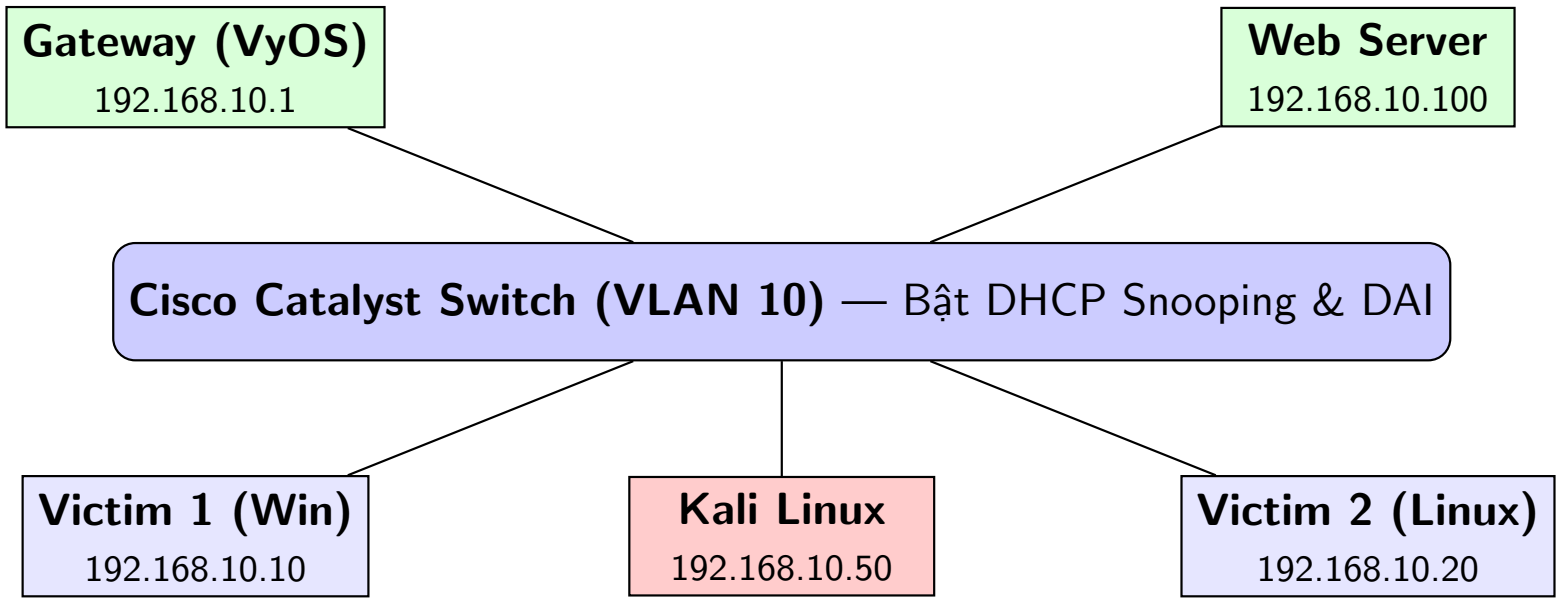
Giả mạo nội dung (Content Tampering)

- Chèn thẻ mã độc JavaScript (`<script src="hook.js">`) kết nối trình duyệt vào khung BeEF.
- Sửa đổi tham số giao dịch trong form POST (thay đổi số tài khoản nhận tiền).

Nội dung

1. Đặt vấn đề & Mục tiêu nghiên cứu
2. Các kỹ thuật khai thác & dẫn đường MitM
3. Mô hình phòng thử nghiệm (Testbed Lab)
4. Giải pháp phòng chống & Kiểm chứng thực nghiệm
5. Đánh giá kết quả & Kết luận

Kiến trúc mô hình Testbed Lab 5 thành phần



- **Phân đoạn mạng:** 192.168.10.0/24 (VLAN 10 an toàn độc lập).
- **Cổng Switch:** Gi1/0/1 (Gateway - **Trusted**), Fa1/0/1 - Fa1/0/3 (**Untrusted**).

Nội dung

1. Đặt vấn đề & Mục tiêu nghiên cứu
2. Các kỹ thuật khai thác & dẫn đường MitM
3. Mô hình phòng thử nghiệm (Testbed Lab)
4. Giải pháp phòng chống & Kiểm chứng thực nghiệm
5. Đánh giá kết quả & Kết luận

Giải pháp 1: HTTPS kết hợp cơ chế HSTS

- **Cấu hình Nginx Web Server:**
  - Kích hoạt giao thức TLS 1.3 và chứng chỉ số X.509 hợp lệ.
  - Bổ sung tiêu đề HSTS bắt buộc:

```
Strict-Transport-Security: max-age=31536000;
includeSubDomains; preload
```

- **Kiểm chứng chạy lại tấn công SSL Stripping:**
  - Trình duyệt của Victim tự động nâng cấp nội bộ lên HTTPS (`Internal 307 Redirect`) trước khi gửi ra mạng.
  - Kẻ tấn công Bettercap không thể đón đầu yêu cầu HTTP.
  - **Kết quả:** Tấn công SSL Stripping bị **vô hiệu hóa 100%**.

Giải pháp 2: DHCP Snooping trên Switch

- **Cấu hình trên Cisco Catalyst Switch:**
  - `ip dhcp snooping` và `ip dhcp snooping vlan 10`.
  - Cổng kết nối Gateway hợp pháp: `ip dhcp snooping trust`.
  - Cổng kết nối người dùng/Attacker: Mặc định là **Untrusted**.
- **Kiểm chứng chạy lại tấn công Rogue DHCP Server:**
  - Kali phát tán gói tin DHCP Offer giả mạo trên cổng Untrusted.
  - Switch phát hiện và lập tức **DROP toàn bộ gói tin Offer** từ cổng này.
  - **Kết quả:** Nạn nhân 100% chỉ nhận IP từ Gateway thật; ngăn chặn triệt để Rogue DHCP.

Giải pháp 3: Dynamic ARP Inspection (DAI)

- **Cơ chế hoạt động:**
  - Switch đối chiếu từng gói ARP trên cổng Untrusted với **DHCP Snooping Binding Table**.
  - Nếu cặp IP-MAC không khớp: Lập tức **DROP** và ghi log cảnh báo vi phạm.
- **Kiểm chứng chạy lại tấn công ARP Cache Poisoning:**
  - Kali chạy kịch bản `arpspoof` mạo nhận IP Gateway `192.168.10.1`.
  - Switch phát hiện MAC Kali không trùng khớp với IP Gateway trong bảng Binding.
  - Switch ghi nhận log: `%SW_DAI-4-DHCP_SNOOPING_DENY: 1 invalid ARPs...`
  - **Kết quả:** Bảng ARP của Victim hoàn toàn trong sạch; ARP Spoofing bị triệt tiêu tận gốc.

Giải pháp 4 & 5: VPN WireGuard & Giám sát ARP bất thường

Đường hầm mã hóa VPN

- Kích hoạt kết nối VPN WireGuard giữa Victim và Gateway.
- Toàn bộ dữ liệu được mã hóa bằng thuật toán ChaCha20-Poly1305.
- Bắt gói tin trên mạng LAN chỉ thu được gói tin UDP mã hóa, không thể đọc dữ liệu.

Giám sát ARP bất thường

- Vận hành Arpwatch và kịch bản phân tích ARP thời gian thực.
- Phát hiện ngay hiện tượng xung đột MAC (MAC Flapping) của Gateway.
- Gửi cảnh báo tức thì tới quản trị viên để cách ly thiết bị vi phạm.

Nội dung

1. Đặt vấn đề & Mục tiêu nghiên cứu
2. Các kỹ thuật khai thác & dẫn đường MitM
3. Mô hình phòng thử nghiệm (Testbed Lab)
4. Giải pháp phòng chống & Kiểm chứng thực nghiệm
5. Đánh giá kết quả & Kết luận

Bảng tổng hợp kết quả đối sánh định lượng

Kịch bản kiểm thử	Chỉ số đo lường	Trước phòng vệ	Sau khi bảo vệ
ARP Poisoning	Tỷ lệ làm sai lệch bảng ARP	100% (Nhiễm độc)	**0% (Bị DAI Drop)**
Lộ mật khẩu HTTP	Số tài khoản bị lộ bản rõ	10/10 lần	**0/10 (Mã hóa TLS)**
Rogue DHCP	Nạn nhân nhận IP lậu	90%	**0% (Bị Drop)**
SSL Stripping	Hạ cấp thành công kết nối	10/10 lần	**0/10 (HSTS chặn)**
Cookie / Session	Chiếm quyền phiên thành công	100%	**0% (Bảo vệ)**
Sniffing qua VPN	Tỷ lệ dữ liệu bị đọc lén	100%	**0% (UDP mã hóa)**

Kết luận và Đóng góp của đề tài

- **Kết luận:**
  - Tấn công Man-in-the-Middle là mối đe dọa nghiêm trọng khai thác trực diện điểm yếu không xác thực của các giao thức mạng cổ điển.
  - Không có một giải pháp đơn lẻ nào đủ an toàn; bắt buộc phải triển khai mô hình **phòng thủ theo chiều sâu (Defense-in-Depth)**.
- **Đóng góp của đề tài:**
  - Hệ thống hóa toàn diện lý thuyết tấn công và phòng chống MitM.
  - Xây dựng thành công mô hình Testbed Lab 5 node kiểm chứng trực quan.
  - Cung cấp bộ kịch bản PoC và cấu hình mẫu sẵn sàng ứng dụng cho hệ thống mạng trường học và doanh nghiệp.

Hướng phát triển tiếp theo

1. Nghiên cứu mở rộng các kỹ thuật MitM trên giao thức thế hệ mới **IPv6** (như Rogue Router Advertisement, Neighbor Discovery Spoofing) và cơ chế RA Guard.
2. Ứng dụng **Trí tuệ nhân tạo (Machine Learning)** để phát hiện bất thường luồng lưu lượng MitM theo thời gian thực.
3. Tích hợp cơ chế phòng vệ tự động vào kiến trúc mạng điều khiển bằng phần mềm (**SDN**).

Đáp ứng tiêu chuẩn đánh giá Niên luận (Mẫu Khoa 2026)

1. Quyển báo cáo (4.0 đ)

- **Hình thức (1.0 đ):** Đúng chuẩn lề 3-2-2-2, Times 13pt, giãn dòng 1.3, trích dẫn IEEE/BibLaTeX 100% nhất quán.
- **Nội dung (3.0 đ):** 4 chương mạch lạc, phân tích sâu 6 kỹ thuật dẫn đường và 5 giải pháp phòng vệ.

2. Sản phẩm (4.0 đ)

- **Giao diện (1.0 đ):** Hệ sinh thái Docsify trực quan, lab web testbed DVWA thân thiện.
- **Demo mô hình (3.0 đ):** Testbed 5 node, PoC chạy mượt mà, cấu hình Cisco DAI, HSTS, VPN và script cảnh báo ARP.

3. Trình bày (2.0 đ)

- **Thuyết trình:** Mạch lạc, tự tin, slide Beamer trực quan.
- **Phản biện:** Nắm vững bản chất gói tin tầng 2 và tầng 7, trả lời thuyết phục các câu hỏi.

XIN TRÂN TRỌNG CẢM ƠN

Quý Thầy, Cô trong Hội đồng và các bạn đã chú ý lắng nghe!

Em rất mong nhận được những câu hỏi và ý kiến đóng góp của Quý Thầy, Cô!